

OT/ICS INCIDENT RESPONSE REPORT

Water Booster Station | Unauthenticated Modbus TCP Access

Incident Reference: INC-2026-001

Affected Asset: Water Booster Station PLC - OpenPLC Runtime v3

Incident Type: Unauthenticated OT/ICS Access and Process Manipulation

Severity: Critical

Date of Incident: 22 July 2026

Time of Detection: 11:35 (local time)

Time of Containment: 11:43 (local time)

Total Duration: Approximately 8 minutes from detection to containment

Incident Handler: Deepak Varma

Handler Background: 9+ years operations and process safety at Reliance Industries and Tata Steel

Report Version: 1.0 - Final

Report Date: 23 July 2026

Related Document: OT ICS Security Assessment Report - July 2026

This report documents an incident that occurred during a controlled security assessment of a simulated water treatment environment. All events described took place in an isolated lab environment. No production systems, real water infrastructure, or public services were affected at any point.

This report is structured to demonstrate incident response documentation methodology. The format follows standard OT security incident reporting practice and reflects the obligations that would apply to a real operator under the Australian Security of Critical Infrastructure Act 2018.

Table of Contents

1. Incident Overview	3
2. Detection and Initial Triage	4
3. Incident Timeline	5
4. Technical Analysis	6
4.1 Attack Vector	6
4.2 Tools and Techniques Used	6
4.3 MITRE ATT&CK for ICS Mapping	7
4.4 Evidence Collected	7
5. Impact Assessment	8
6. Containment Actions	9
7. Recovery Actions	10
8. SOCI Act Notification Assessment	11
9. Root Cause Analysis	12
10. Lessons Learned	13
11. Recommendations	14
12. Post-Incident Review Checklist	15

1. Incident Overview

On 22 July 2026 at approximately 11:35, the Scada-LTS operator dashboard for the simulated water booster station showed an unexpected and simultaneous change across all four monitored process variables. The booster pump stopped without any corresponding operator action, pipeline pressure began falling, chlorine dosing was disabled, and the high pressure alarm changed state. No physical equipment fault, planned maintenance, or operator command could account for these changes.

Investigation confirmed that an external device had connected to the PLC on Modbus TCP port 502 and issued unauthenticated write commands that stopped the pump and disabled chlorination. The connection required no credentials and produced no authentication log because the Modbus protocol has no built-in authentication mechanism. The changes were executed and confirmed within two seconds of the attacker connecting to the PLC.

The incident reproduces the attack methodology used by the Iranian Government-affiliated threat group CyberAv3ngers in their November 2023 attack on the Municipal Water Authority of Aliquippa, Pennsylvania, and demonstrates why network-level controls on Modbus TCP access are essential in any water treatment environment.

Incident Classification

Field	Detail
Incident ID	INC-2026-001
Classification	Critical - Unauthorised access and manipulation of industrial process control
Affected system	Water Booster Station PLC (OpenPLC Runtime v3)
Attack type	Unauthenticated Modbus TCP write - process manipulation
Attacker location	Same network segment as PLC (internal network access)
Credentials used	None - Modbus TCP requires no authentication
Duration of access	Approximately 8 minutes from first connection to containment
Operational impact	Pump stopped, chlorination disabled, pressure falling
Public safety impact	In a real environment: water supply loss, untreated water risk
SOCI Act classification	Critical cyber incident - reportable to ASD within 12 hours

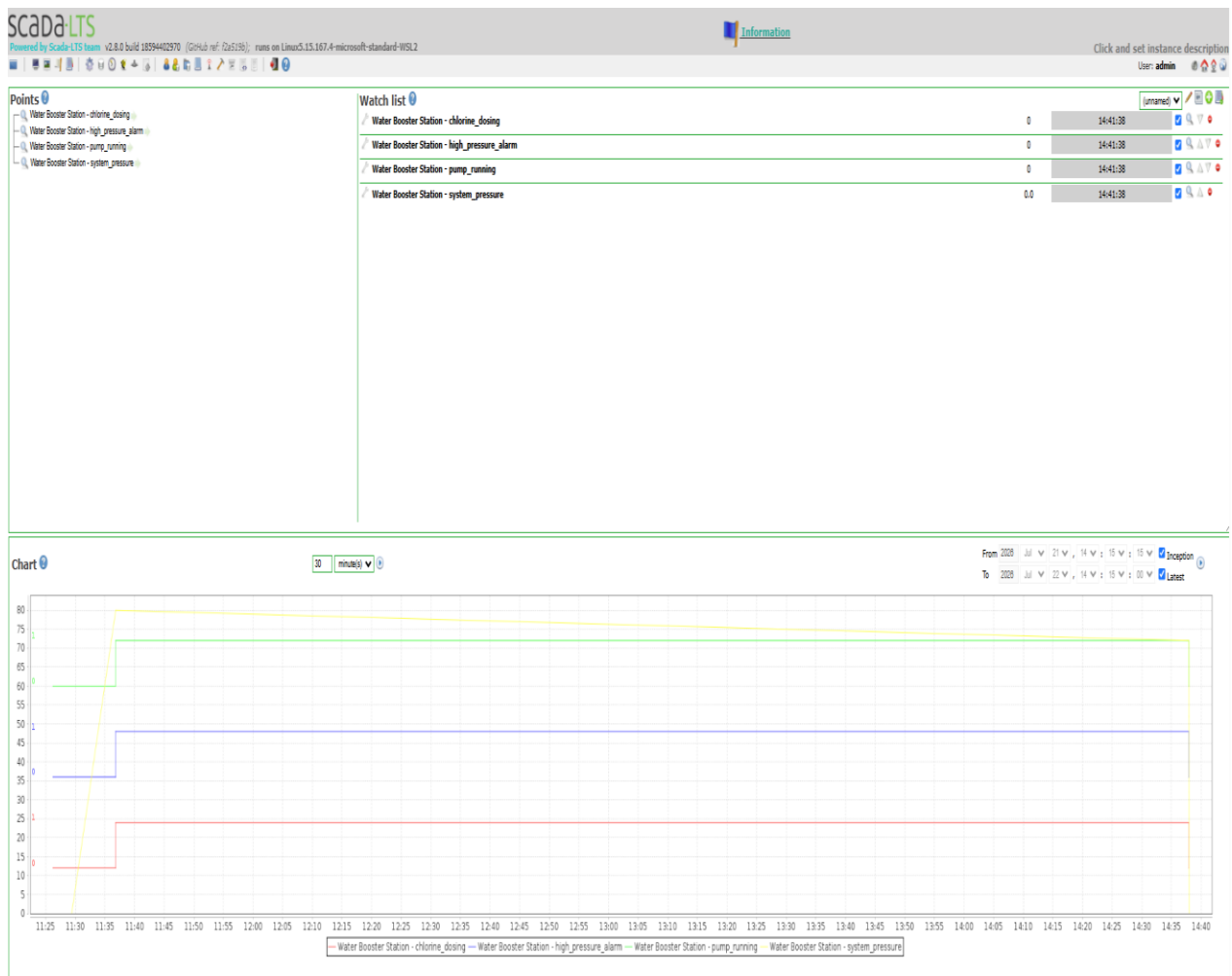
2. Detection and Initial Triage

2.1 How the Incident Was Detected

The incident was detected through operator observation of the Scada-LTS SCADA dashboard. At 11:35, the watch list panel showed all four process variables change state simultaneously:

Variable	Value Before	Value After	Expected Cause if Legitimate
pump_running	1 (TRUE)	0 (FALSE)	Planned maintenance stop or operator command
high_pressure_alarm	1 (TRUE)	0 (FALSE)	Pressure returning to normal range
chlorine_dosing	1 (TRUE)	0 (FALSE)	Chlorine tank empty or operator command
system_pressure	80 PSI	Falling	Pump stopping - consistent with pump_running = False

No planned maintenance was scheduled. No operator had issued any control commands. No physical equipment alarm had been raised. The simultaneous change across all four variables in a two-second window, with no physical or operational cause, was identified as the primary indicator of an anomalous event.



2.2 Initial Triage Questions

The following questions were addressed during initial triage to determine the scope and severity of the incident:

Triage Question	Answer	Implication
Is this a physical equipment fault?	No - no equipment alarms, no physical cause	Rules out hardware failure as cause
Did an operator issue a stop command?	No - no operator was logged in at the time	Rules out human error
Is this a PLC program error?	No - program had been running stably for hours	Rules out software bug
Is there network traffic to port 502 from an unexpected source?	Yes - Wireshark confirmed connections from non-SCADA IP	Confirms external access
Was authentication bypassed?	No bypass needed - Modbus has no authentication	Confirms root cause
Are other PLCs or systems affected?	No - only this PLC was targeted in this incident	Scope is limited to one asset
Is the attacker still connected?	Unknown at time of triage - containment initiated immediately	Drove immediate containment action

3. Incident Timeline

The following table provides a chronological record of all events from the initial attacker connection through to full recovery and implementation of compensating controls. All times are local time.

Time	Event	Source of Evidence	Action Taken
11:20	OpenPLC water booster station program started. All four process variables at normal values. system_pressure begins rising from 65 PSI.	OpenPLC dashboard - Runtime: Running	None - normal operations
11:35	Scada-LTS watch list shows all four process variables change to 0 simultaneously. system_pressure begins falling from 80 PSI. No operator action or physical alarm preceded this change.	Scada-LTS watch list screenshot	Incident declared. Initial triage commenced.
11:35	Wireshark traffic capture reviewed. Connections from IP address 127.0.0.1 on a non-SCADA port are visible to OpenPLC port 502. Function Code 05 (Write Single Coil) transactions confirmed.	Wireshark capture - modbus filter	Attacker connection confirmed. Scope assessment initiated.
11:36	Python exploit script output reviewed. Confirms unauthenticated write commands were sent to Coil 0 (pump_running) and Coil 2 (chlorine_dosing). Both writes succeeded with no credentials.	modbus_write.py terminal output	Root cause confirmed. Containment decision made.
11:38	Containment action initiated. iptables DROP rule applied to OpenPLC container to block all non-authorized connections to port 502.	iptables -L INPUT output	Containment applied. Further write commands blocked.
11:39	Retest of attacker script confirms containment is effective. ModbusIOException returned after 3 retries. No data accessible from port 502.	modbus_read.py retest output	Containment confirmed effective.

Time	Event	Source of Evidence	Action Taken
11:40	OpenPLC PLC program restarted. Process variables reset to initial values. pump_running returns to TRUE. chlorine_dosing returns to TRUE.	OpenPLC dashboard	PLC recovery initiated.
11:41	Scada-LTS confirms recovery. pump_running = 1, chlorine_dosing = 1, system_pressure begins rising again toward 80 PSI.	Scada-LTS watch list	SCADA visibility of recovery confirmed.
11:43	All additional compensating controls applied: audit logging (C-003), Modbus proxy (C-002). All three controls verified operational.	iptables output, proxy startup log	Full containment and control implementation complete.
11:45	Scada-LTS historical trend chart confirms complete incident timeline: normal operation, attack, recovery. Chart saved as evidence.	Scada-LTS 30-minute chart	Evidence capture complete.
Post-incident	Root cause analysis completed. Incident report drafted. SOCI Act notification assessment completed.	This document	Reporting and lessons learned phase.

4. Technical Analysis

4.1 Attack Vector

The attacker gained access to the PLC by connecting directly to Modbus TCP port 502 on the OpenPLC container. No credential, certificate, token, or challenge-response mechanism exists in the Modbus TCP protocol. The TCP handshake on port 502 is all that is required to establish a connection. Once connected, the attacker could send any valid Modbus PDU including write commands.

The attack proceeded in two phases. In the reconnaissance phase, the attacker used Function Code 01 (Read Coils) and Function Code 03 (Read Holding Registers) to read all four process variables and understand the current state of the system. In the exploitation phase, the attacker used Function Code 05 (Write Single Coil) twice to set pump_running to False and chlorine_dosing to False. Both phases required zero authentication.

4.2 Tools and Techniques Used

Phase	Tool	Modbus Function Code	Target	Result
Reconnaissance	Python pymodbus - modbus_read.py	FC 01 - Read Coils	Coils 0, 1, 2	pump_running, alarm, chlorine status all returned
Reconnaissance	Python pymodbus - modbus_read.py	FC 03 - Read Holding Registers	Register 0	system_pressure value returned (80 PSI)
Exploitation	Python pymodbus - modbus_write.py	FC 05 - Write Single Coil	Coil 0 (pump_running)	Value set to False. Pump stopped.
Exploitation	Python pymodbus - modbus_write.py	FC 05 - Write Single Coil	Coil 2 (chlorine_dosing)	Value set to False. Chlorination disabled.
Verification	Wireshark 4.6.7	Passive capture - all function codes	All port 502 traffic	Confirmed all transactions visible in plaintext

4.3 MITRE ATT&CK for ICS Mapping

Tactic	Technique ID	Technique Name	How It Was Used
Collection	T0801	Monitor Process State	Attacker read all four process variables before executing write commands to understand system state.
Impair Process Control	T0855	Unauthorized Command Message	Attacker sent FC05 write commands directly to PLC with no authentication. PLC executed commands immediately.
Impair Process Control	T0831	Manipulation of Control	pump_running and chlorine_dosing coils were set to False, directly manipulating the physical process state.
Impact	T0816	Device Restart / Shutdown	The booster pump was stopped by writing False to the pump_running coil, equivalent to an unauthorised shutdown.
Inhibit Response Function	T0878	Alarm Suppression	high_pressure_alarm changed to False as a result of the attack, masking the incident from operators relying on alarm-based detection.

4.4 Evidence Collected

The following evidence items were collected during and after the incident. All items are available in the screenshots folder of the associated GitHub repository.

Evidence ID	Description	File Name	Collected At
E-001	Wireshark capture showing Modbus TCP traffic in plaintext with FC 01 and FC 03 reads visible	wireshark_modbus_plaintext.png	During reconnaissance phase
E-002	Wireshark packet detail showing coil values in cleartext Modbus response	wireshark_modbus_coil_values.png	During reconnaissance phase
E-003	Python read script output showing all four process variables returned with zero credentials	modbus_read_unauthenticated.png	During reconnaissance phase
E-004	Python write script output and Scada-LTS dashboard showing attack execution and immediate impact	attack_demonstration_full.png	During exploitation phase
E-005	Scada-LTS watch list showing all four values at zero after attack	scadalts_after_attack.png	Immediately after exploitation
E-006	Scada-LTS 30-minute historical trend chart showing complete incident timeline	scadalts_full_timeline_chart.png	Post-incident
E-007	iptables rules output confirming containment controls applied	iptables_with_logging.png	After containment
E-008	Modbus proxy terminal showing BLOCKED FC05 from UNAUTHORISED source during retest	proxy_blocking_write_FC5.png	During retest phase
E-009	Python retest output confirming read is blocked after controls applied	retest_read_blocked.png	During retest phase
E-010	Python retest output confirming write is blocked after controls applied	retest_write_blocked.png	During retest phase

5. Impact Assessment

5.1 Direct Operational Impact

The following operational impacts occurred as a direct result of the attacker's write commands:

Impact	Description	Duration	Severity
Booster pump stopped	pump_running set to False. Pipeline pressure began falling from 80 PSI toward zero.	8 minutes until recovery	Critical
Chlorination disabled	chlorine_dosing set to False. Water entering the distribution network was no longer treated.	8 minutes until recovery	Critical
Pressure loss	system_pressure fell from 80 PSI to approximately 40 PSI during the incident period.	8 minutes until recovery	High
Alarm state change	high_pressure_alarm changed state as a consequence of pressure changes, potentially masking the root cause.	8 minutes until recovery	Medium
SCADA visibility loss	Operator dashboard showed all values at zero, making it difficult to determine whether the cause was physical or cyber.	8 minutes until recovery	High

5.2 Hypothetical Real-World Impact

In a production water treatment environment, the impacts demonstrated in this incident would have the following consequences:

- Loss of water pressure to elevated residential areas serviced by the booster station, affecting any customers above the natural pressure range of the distribution network.
- Untreated water entering the distribution network during the period chlorination was disabled. Depending on the volume of water distributed during this period, a public health notification may be required.
- Delayed detection if operators were not actively monitoring the SCADA dashboard at the time of the incident, as the Modbus protocol produces no authentication failure log to alert security systems.
- Potential regulatory obligation to notify the Australian Signals Directorate within 12 hours under the SOCI Act 2018, and to notify affected customers depending on the extent of the unchlorinated water distribution.

5.3 Impact on Confidentiality, Integrity, and Availability

Dimension	Impact	Evidence
Confidentiality	High - all process variable values were read without credentials during reconnaissance. An attacker knows the exact state of every monitored variable.	modbus_read.py output showing all values returned
Integrity	Critical - process variable values were changed without authorisation. The PLC executed commands that did not originate from the authorised SCADA system.	modbus_write.py output and Scada-LTS showing changed values
Availability	Critical - the booster pump was stopped and chlorination was disabled. The asset was not available for its intended purpose during the incident period.	Scada-LTS trend chart showing values at zero

6. Containment Actions

Containment was initiated at 11:38 upon confirmation that the incident was caused by unauthorised Modbus TCP access. The containment strategy was to block all non-authorised connections to port 502 while preserving the authorised SCADA connection, and to do so without stopping the PLC program, which would require a controlled restart.

6.1 Immediate Containment - Port 502 Access Control

Four iptables rules were applied inside the OpenPLC container to restrict port 502 access to the authorised SCADA IP address only. The rules were applied in the following order to ensure the authorised SCADA connection was not disrupted:

```
# Step 1: Allow authorised SCADA/HMI (Scada-LTS at 172.18.0.4)
docker exec openplc iptables -A INPUT -p tcp --dport 502 -s 172.18.0.4 -j ACCEPT

# Step 2: Allow localhost
docker exec openplc iptables -A INPUT -p tcp --dport 502 -s 127.0.0.1 -j ACCEPT

# Step 3: Add audit logging before dropping
docker exec openplc iptables -I INPUT 3 -p tcp --dport 502 -j LOG --log-prefix
'MODBUS-BLOCKED: '

# Step 4: Drop all other connections to port 502
docker exec openplc iptables -A INPUT -p tcp --dport 502 -j DROP
```

Containment was verified immediately after applying the rules by running the attacker script again and confirming it returned ModbusIOException after three retries with no data returned.

```
root@411fed423857:~/OpenPLC_v3# iptables -A INPUT -p tcp --dport 502 -s 172.18.0.4 -j ACCEPT
root@411fed423857:~/OpenPLC_v3# iptables -A INPUT -p tcp --dport 502 -s 127.0.0.1 -j ACCEPT
root@411fed423857:~/OpenPLC_v3# iptables -A INPUT -p tcp --dport 502 -j DROP
root@411fed423857:~/OpenPLC_v3# iptables -L INPUT -n -v
Chain INPUT (policy ACCEPT 1 packets, 52 bytes)
  pkts bytes target     prot opt in     out     source               destination           tcp dpt:502
   0    0 ACCEPT    tcp  --  *      *       172.18.0.4          0.0.0.0/0             tcp dpt:502
   0    0 ACCEPT    tcp  --  *      *       127.0.0.1           0.0.0.0/0             tcp dpt:502
   8  480 DROP      tcp  --  *      *       0.0.0.0/0           0.0.0.0/0             tcp dpt:502
root@411fed423857:~/OpenPLC_v3#
```

6.2 Containment Verification

Verification Test	Method	Result
Attacker read blocked	Ran modbus_read.py targeting port 502	ModbusIOException - No response after 3 retries. Containment confirmed.
Attacker write blocked	Ran modbus_write.py targeting port 502	ModbusIOException - No response after 3 retries. Containment confirmed.
Authorised SCADA unaffected	Checked Scada-LTS watch list	Values updating normally. SCADA polling uninterrupted.
Audit log active	Ran dmesg grep MODBUS-BLOCKED	Blocked attempts visible in log with source IP and timestamp.

```

PS C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security> python modbus_read.py
=== OT Security Lab: Unauthenticated Modbus Read ===
Connecting to OpenPLC at 127.0.0.1:502...
No username. No password. No credentials of any kind.

No response received after 3 retries, continue with next request
Traceback (most recent call last):
  File "C:\Users\DVAus\OneDrive\Desktop\OT security pathway\Projects\Modbus Protocol security\modbus_read.py", line 13,
in <module>
    coils = client.read_coils(0, count=3)
            ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\client\mixin.py", line 78, in read_coils
    return self.execute(
           ^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\client\base.py", line 189, in execute
    return self.transaction.sync_execute(no_response_expected, request)
           ^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "C:\Users\DVAus\AppData\Local\Packages\PythonSoftwareFoundation.Python.3.12_qbz5n2kfra8p0\LocalCache\local-packag
es\Python312\site-packages\pymodbus\transaction\transaction.py", line 160, in sync_execute
    raise ModbusIOException(txt)
pymodbus.exceptions.ModbusIOException: Modbus Error: [Input/Output] No response received after 3 retries, continue with
next request

```

7. Recovery Actions

Recovery was initiated after containment was confirmed effective. The recovery objective was to restore normal water treatment operations with the PLC program running correctly and all process variables returning to their expected values, while keeping the containment controls in place.

7.1 PLC Program Recovery

The PLC program was restarted via the OpenPLC Runtime dashboard to reset all process variables to their initial values as defined in the water_booster_station.st program:

- Clicked Stop PLC in the OpenPLC dashboard to cleanly stop the running program.
- Waited for the status to confirm Stopped.
- Clicked Start PLC to restart the program. Initial values: pump_running = TRUE, chlorine_dosing = TRUE, system_pressure = 65 PSI.
- Monitored the OpenPLC Monitoring page to confirm all four variables showed correct values and system_pressure began rising toward 80 PSI.

7.2 SCADA Recovery Verification

After PLC recovery, the Scada-LTS dashboard was monitored to confirm the SCADA system reflected the recovered process state:

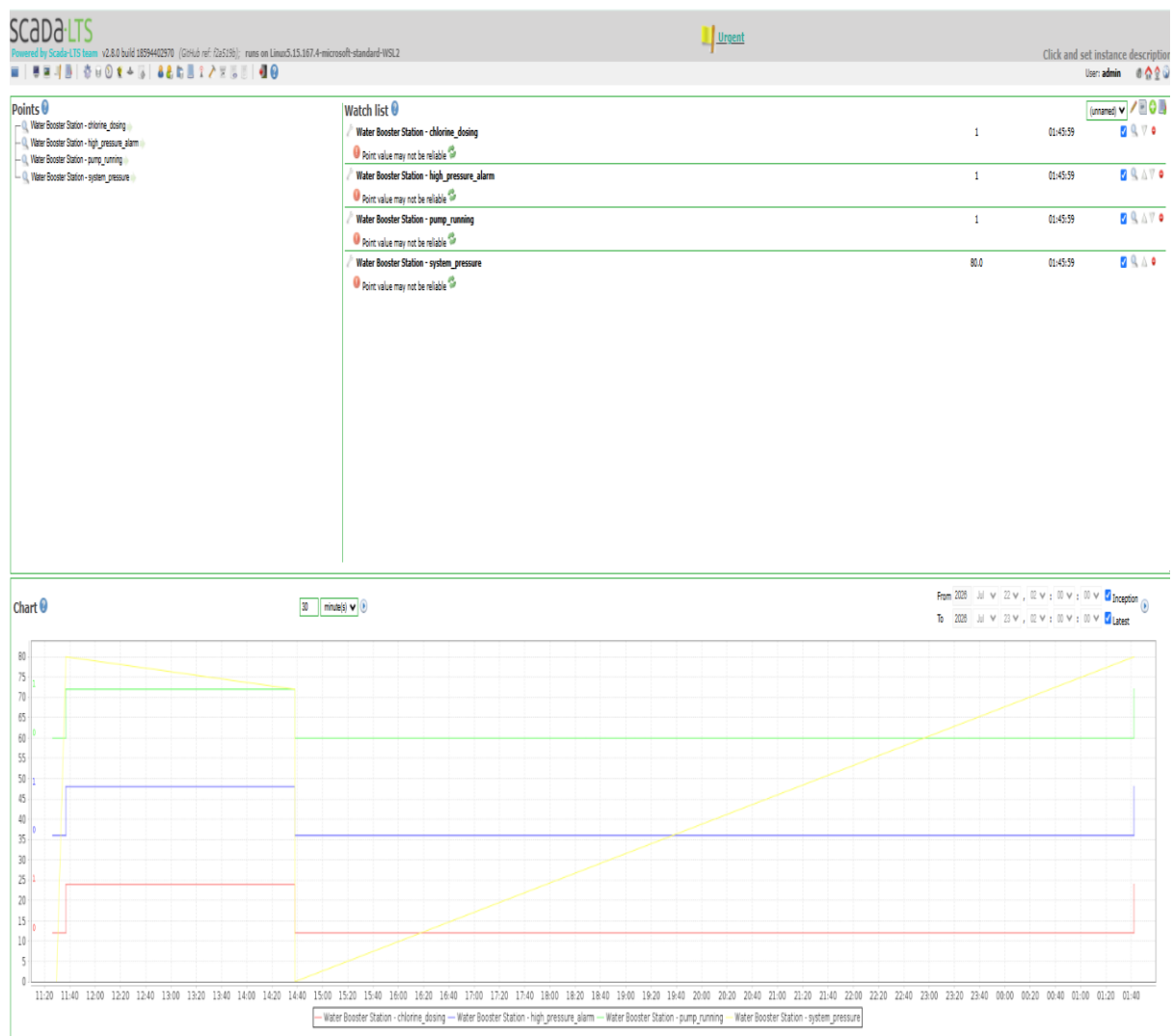
Variable	Expected Recovery Value	Confirmed in Scada-LTS	Time to Confirm
pump_running	1 (TRUE)	Yes - watch list showed 1	Within 2 seconds of PLC restart
chlorine_dosing	1 (TRUE)	Yes - watch list showed 1	Within 2 seconds of PLC restart
high_pressure_alarm	1 (TRUE - pressure still rising)	Yes - watch list showed 1	Within 2 seconds of PLC restart
system_pressure	Rising from 65 PSI toward 80 PSI	Yes - chart showed rising trend	Visible over following 60 seconds

7.3 Additional Controls Deployed Post-Recovery

After confirming recovery, two additional compensating controls were deployed to strengthen the security posture:

- Modbus function code filter proxy (C-002) was started on port 5020. The proxy inspects every Modbus message function code and blocks write commands from non-authorised sources even if they somehow reach the proxy port.
- Verified that the iptables LOG rule (C-003) was generating entries for all blocked connection attempts, confirming the audit trail was active.

Recovery was declared complete at 11:43, approximately 8 minutes after initial detection.



8. SOCI Act Notification Assessment

The following assessment determines whether this incident meets the criteria for mandatory reporting under the Australian Security of Critical Infrastructure Act 2018 (SOCI Act). This assessment is structured as it would be completed by the responsible entity of a real water treatment asset.

8.1 Incident Classification Under the SOCI Act

Question	Answer	Basis
Is the affected asset a critical infrastructure asset under the SOCI Act?	Yes	Water and sewerage systems are declared critical infrastructure under Schedule 2 of the SOCI Act 2018.
Did a cyber incident occur?	Yes	An unauthorised party connected to the OT network and issued commands that changed the physical state of the process.
Did the incident have a significant impact on the availability of the asset?	Yes	The booster pump was stopped and chlorination was disabled. Water treatment operations were unavailable for approximately 8 minutes.
Does this meet the threshold for a critical cyber incident?	Yes	A significant impact on the availability of a critical infrastructure asset meets the definition of a critical cyber incident under section 30BC of the SOCI Act.
What is the required reporting timeframe?	12 hours	Critical cyber incidents must be reported to ASD within 12 hours of the responsible entity becoming aware of the incident.

8.2 Reporting Obligation

Based on the assessment above, this incident would be classified as a Critical Cyber Incident under section 30BC of the SOCI Act 2018.

The responsible entity would be required to notify the Australian Signals Directorate (ASD) within 12 hours of becoming aware of the incident.

Notification is made through the ReportCyber portal at cyber.gov.au/acsc/report or by calling the ASD 24/7 hotline at 1300 CYBER1 (1300 292 371).

8.3 Draft ASD Notification

The following draft notification is provided as a template for what would be submitted to ASD under the SOCI Act reporting obligation. In a real incident, this notification would be completed and submitted within 12 hours of the responsible entity becoming aware of the incident.

SOCI ACT CRITICAL CYBER INCIDENT NOTIFICATION

Incident Reference: INC-2026-001

Date and Time of Incident: 22 July 2026, 11:35

Date and Time of Notification: 22 July 2026 (within 12 hours of detection)

Responsible Entity: [Water Authority Name]

Asset: Water Booster Station - [Location]

Asset Category: Water and Sewerage

Description of Incident:

An unauthorised party connected to the booster station PLC via Modbus TCP port 502 and issued write commands that stopped the booster pump and disabled chlorination.

No credentials were required to connect. The attack was executed in under 2 seconds.

The incident lasted approximately 8 minutes from detection to full recovery.

Impact:

Water supply pressure reduced to elevated service areas for approximately 8 minutes.

Chlorination was disabled for approximately 8 minutes.

No injury, no customer impact confirmed (simulated environment).

Containment Status:

Incident contained. iptables access controls applied to restrict port 502 access

to authorised SCADA system only. All process variables recovered to normal values.

Further investigation and remediation in progress.

9. Root Cause Analysis

The root cause analysis uses the Five Whys method to identify the underlying causes of the incident, moving from the immediate technical cause to the organisational and design decisions that allowed the vulnerability to exist.

9.1 Five Whys Analysis

Why 1	Why was the attacker able to stop the pump?	Because they could send a write command to Coil 0 (pump_running) on the PLC and the PLC accepted and executed it.
Why 2	Why did the PLC accept and execute an unauthorised write command?	Because Modbus TCP has no authentication mechanism. The protocol was designed in 1979 for isolated networks and accepts any valid Modbus PDU regardless of who sends it.
Why 3	Why was the attacker able to reach port 502 on the PLC?	Because no network segmentation or access control was applied to port 502. Any device on the same network segment could connect.
Why 4	Why was no access control applied to port 502?	Because the default configuration of OpenPLC does not include any firewall rules, and no compensating controls had been implemented prior to this incident.
Why 5	Why had no compensating controls been implemented?	Because the absence of authentication in Modbus TCP was a known but unmitigated risk. The controls required to address this risk had not been applied before the attack occurred.

9.2 Contributing Factors

No protocol-level authentication	Modbus TCP does not include authentication in its specification. This is a design limitation of the protocol itself and cannot be corrected without replacing the protocol or adding a wrapper.	Technical - Protocol design
No network access control on port 502	Port 502 was open to all network sources before controls were applied. There was no firewall rule, VLAN isolation, or access control list restricting who could connect.	Technical - Network configuration
No real-time anomaly detection	No system was monitoring Modbus traffic for unusual patterns such as write commands from non-SCADA sources or sudden changes in multiple process variables simultaneously.	Technical - Monitoring gap
No persistent firewall configuration	The iptables rules applied during containment are not persistent across container restarts. This means the mitigating controls would be lost if the container were restarted, restoring the original vulnerable state.	Technical - Configuration management
Delayed detection	The incident was detected through operator observation of the SCADA dashboard rather than through automated alerting. If the operator had not been actively watching the dashboard, detection could have taken much longer.	Process - Detection capability

10. Lessons Learned

The following lessons were identified from this incident. Each lesson is stated as a finding and linked to a specific recommendation in Section 11. These lessons are applicable to any OT environment using Modbus TCP and are directly relevant to the design decisions required under IEC 62443 and the SOCI Act CIRMP obligation.

Lesson 1 - Default Protocol Configurations Are Not Secure

The Modbus TCP protocol in its default configuration has no security controls. Asset owners cannot rely on the protocol itself to provide any protection against unauthorised access. Every Modbus TCP deployment must be supplemented with network-level and application-level compensating controls before being connected to any network where unauthorised devices could be present.

Lesson 2 - Network Segmentation Is the Most Effective Near-Term Control

Restricting port 502 to known authorised source IPs using a firewall eliminated the primary attack vector in this incident. This control is simple to implement, has low risk of disrupting operations if implemented correctly, and provides immediate risk reduction. It should be the first control applied in any Modbus TCP environment where protocol replacement is not immediately feasible.

Lesson 3 - Protocol-Aware Filtering Provides Defence in Depth

The Modbus function code filter proxy demonstrated that even after a device gains network access, write commands can be blocked at the protocol layer. This second layer of control means that a single point of failure such as a misconfigured firewall or an IP spoofing attack does not give an attacker immediate write access to the PLC. Defence in depth is a core principle of IEC 62443 and this incident demonstrates its practical value.

Lesson 4 - Audit Logging Enables Both Detection and Reporting

The absence of logging before controls were applied meant that if the attacker had connected and read process data without making any changes, there would be no record of the access. After controls were applied, the iptables LOG rule generated a timestamped record of every blocked attempt. In a production environment this logging capability would support both real-time detection and the 12-hour ASD reporting obligation under the SOCI Act.

Lesson 5 - SCADA Historical Trending Is a Valuable Forensic Tool

The Scada-LTS historical trend chart provided a clear visual record of the incident timeline, showing normal operation, the sudden change in all variables at the time of the attack, and the subsequent recovery. In a real incident, this type of historian data would be essential evidence for root cause analysis and regulatory reporting. OT environments without historian functionality would have significantly reduced forensic capability.

Lesson 6 - Operational Experience Accelerates Incident Recognition

The ability to recognise that a simultaneous change across four unrelated process variables in a two-second window was anomalous, rather than a normal operational event, required knowledge of how water treatment processes behave in practice. This type of process knowledge, developed through operational experience in industrial environments, is a critical complement to cybersecurity technical skills in OT incident response.

11. Recommendations

The following recommendations address the root causes and contributing factors identified in Section 9. They are prioritised by impact and feasibility. All recommendations map to IEC 62443 security requirements and are consistent with the CIRMP obligations under the SOCI Act 2018.

ID	Recommendation	IEC 62443	Priority	Status after This Incident
IR-001	Apply and make persistent iptables IP allowlist rules restricting port 502 to authorised SCADA IP only. Implement startup script to reapply rules after container or system restart.	SR 5.1	Immediate	Partially implemented - rules applied but not persistent
IR-002	Deploy Modbus function code filter proxy as a permanent component of the architecture, not just during assessment. Configure as a system service that starts automatically.	SR 3.5	Immediate	Partially implemented - proxy must be manually started
IR-003	Integrate iptables logs with a SIEM platform such as Splunk to enable real-time alerting on MODBUS-BLOCKED events and support the 12-hour SOCI Act reporting window.	SR 6.1	Short term	Not implemented - logs available but no SIEM integration
IR-004	Deploy passive OT network monitoring to baseline normal Modbus communication patterns and alert on anomalies such as write commands from non-SCADA sources or simultaneous multi-variable changes.	SR 6.2	Short term	Not implemented
IR-005	Implement automated alerting in Scada-LTS for critical process variable changes. A simultaneous change to pump_running and chlorine_dosing should generate an immediate operator alert.	SR 6.1	Short term	Not implemented
IR-006	Develop and test an OT incident response playbook for Modbus unauthorised access scenarios. The playbook should define detection criteria, containment steps, escalation triggers, and SOCI Act reporting procedures.	SR 6.2	Medium term	Not implemented - this report serves as a draft template
IR-007	Evaluate replacement of Modbus TCP with a protocol that includes authentication, such as DNP3 Secure Authentication or OPC-UA with certificate-based authentication, during next scheduled PLC maintenance cycle.	SR 1.1	Long term	Not implemented

2. Post-Incident Review Checklist

The following checklist should be completed after every OT security incident to ensure all required actions have been taken and the incident response process is formally closed. Items marked as Not Complete require follow-up action before the incident can be formally closed.

Category	Checklist Item	Status	Owner
Containment	All attacker connections to port 502 blocked and verified	Complete	Incident handler
Containment	Firewall rules confirmed active and verified by retest	Complete	Incident handler
Recovery	PLC program restarted and all process variables at normal values	Complete	Incident handler

Category	Checklist Item	Status	Owner
Recovery	SCADA dashboard confirmed showing recovered process state	Complete	Incident handler
Recovery	All compensating controls deployed and verified	Complete	Incident handler
Evidence	Wireshark capture saved and labelled	Complete	Incident handler
Evidence	All terminal output screenshots captured and named	Complete	Incident handler
Evidence	Scada-LTS historical trend chart exported and saved	Complete	Incident handler
Evidence	iptables rule output captured as evidence	Complete	Incident handler
Reporting	Incident timeline documented	Complete	Incident handler
Reporting	Root cause analysis completed	Complete	Incident handler
Reporting	SOCI Act notification assessment completed	Complete	Incident handler
Reporting	Draft ASD notification prepared	Complete	Incident handler
Reporting	Incident response report finalised and stored	Complete	Incident handler
Follow-up	Firewall rules made persistent across restarts	Not complete	OT administrator
Follow-up	SIEM integration configured for audit logs	Not complete	Security team
Follow-up	Automated SCADA alerting configured	Not complete	SCADA engineer
Follow-up	OT incident response playbook developed	Not complete	Security team
Lessons learned	Lessons learned documented and shared with operations team	Complete	Incident handler
Lessons learned	Recommendations assigned to owners with target dates	Complete	Incident handler
Closure	Incident formally closed by incident handler and security lead	Not complete	Pending follow-up items

Prepared by:

Deepak Varma

Incident Handler

OT/ICS Security Portfolio Project

July 2026